
Why Cyber Security is Hard

Author(s): Robert Ghanea-Hercock

Source: *Georgetown Journal of International Affairs*, 2012, International Engagement on Cyber 2012: Establishing Norms and Improving Security (2012), pp. 81-89

Published by: The Johns Hopkins University Press

Stable URL: <https://www.jstor.org/stable/43134341>

JSTOR is a not-for-profit service that helps scholars, researchers, and students discover, use, and build upon a wide range of content in a trusted digital archive. We use information technology and tools to increase productivity and facilitate new forms of scholarship. For more information about JSTOR, please contact support@jstor.org

Your use of the JSTOR archive indicates your acceptance of the Terms & Conditions of Use, available at <https://about.jstor.org/terms>



JSTOR

The Johns Hopkins University Press is collaborating with JSTOR to digitize, preserve and extend access to *Georgetown Journal of International Affairs*

Why Cyber Security is Hard

Robert Ghanea-Hercock

In the twenty-first century we face unprecedented challenges in securing the information assets and intellectual property of our public and private organizations. Yet only a few years ago, the cyber war was often derided and declared a mere nuisance to business as usual. Painful experiences over the past two years, such as the Sony and RSA attacks, have now dispelled this naive stance.¹ The truth of cyber security, however, is both overt and subtle. It is overt in the sense that the arena is now clearly driven by a mix of political expression, such as the Anonymous social hactivism movement, and economic incentives for criminal gangs to state-sponsored industrial espionage. The subtle facet of cyber security, however, is why it remains a difficult problem. Specifically, the mix of technical, policy, and social dimensions have combined to create and complicate a coevolving, complex adaptive system (CAS). This is the essence of the cyber problem. More importantly, once we accept this is the case, it perforce reshapes our entire policy and technical approach to the problem. Ultimately, we cannot solve a CAS; at best we can merely shape and influence its evolution. The article will first overview what we mean by a CAS in the computer domain, and then will review the characteristics of the technical, social, and legal cyber security themes.

Robert Ghanea-Hercock is a Chief Research Scientist in the British Telecommunications Security Research Practice.

Complex Adaptive Systems.

When a bright young student, Robert Morris, released the first self-replicating computer worm in 1988, he was actually making real a vision shared by the founders of computing, John von Neumann and Alan Turing, who both envisaged the ability of computers to mimic the capacity of life to reproduce.² Thus, the power to replicate and evolve was ingrained in the very genesis of modern computing. It is no surprise, therefore, that the emergence of the Internet provided the ideal ecology for malicious self-replicating code to spread and thrive as well. What we now define as malware remains a technical challenge, precisely because of its ability to spread and adapt at machine speed.

biological or ecological system does. There are multiple definitions of CAS, but a sufficient one is by John Holland, a leading thinker in this domain: "CAS [complex adaptive systems] are systems that have large numbers of components, often called agents, that interact and adapt or learn." Ultimately, if we have a large number of interacting agents, such as the global cyber domain, then it may be categorized as a CAS.⁴

Game Theory as a Model for Cyber Security.

A closely related research domain to complex adaptive systems, with which we can understand the issues surrounding cyber security, is a Game Theoretic approach.⁵ Originally developed as a strategic tool in

What we have in the cyber domain is [a] game... where there are far more avenues for attack than there are ways to defend.

Of course this Promethean power has been harnessed, with varying levels of sophistication, by many human actors, from the grassroots political activist to organized criminal gangs or even to state-sponsored spy-rings. It is also understood that a fundamental aspect of the problem is that offense is favored over defense simply by the geography of cyberspace, since only a single point of failure in a cyber network, or process, is required for a successful attack.³ The nature of CAS is such that there is no longer an 'off-switch', as dreamed of by many political commentators. The Internet is now the world's digital nervous system, and suffers from parasitic and predator-prey activity, just as any

the nuclear Cold War, Game Theory studies the choice of optimal behavior when the costs and benefits depend upon the choices of other individuals. What we now have in the cyber domain is an N player game of benign and malicious players, where there are far more avenues for attack than there are ways to defend.⁶ We are therefore in a state of co-evolution, where each new defense strategy leads to co-adaptation by a corresponding set of attacks.

A useful consideration of these aspects can be found in a report by the JASON group, where they state: "Most importantly, the threats associated with cyber-security are dynamic in that the nature and agenda of adver-

saries is continually changing and the type of attacks encountered evolve over time, partly in response to defensive actions...game theoretic ideas will be useful in understanding how to prioritize cyber defense activities. It is not possible to protect everything all the time and so some notion of risk must be established; game theoretic approaches provide a framework for reasoning about such choices.”⁷

With respect to modeling risk, Nassim Taleb in the *Black Swan* discusses the disproportionate role of very high-impact, hard-to-predict events that are beyond normal expectations in history, science, finance, and technology.⁸ For example, in any highly networked system, such as the Internet, the risk distribution is inherently nonlinear. Firstly, the hub and spoke nature of many physical and logical cyber networks greatly accelerates the speed at which replicating code can propagate.⁹ Secondly, the economic or social impact of an attack is not linearly proportional to the scope or size of the attack vector. For example, an eBook containing 500kb of data may retail for \$15, yet a malware exploit and associated code may only contain 5kb of data, yet cause \$100M of damage.¹⁰

Ultimately, the Game Theory approach contains a number of useful models and techniques, and it is likely to emerge as a major element in future strategies for developing cyber defense processes.

Technical Dimension. There are a number of inherent technical complexities that stem from the CAS model. For example, intent is crucial in any combat scenario, but how do we infer

the intent of a malware source agency? Are the attackers simply hunting for an easy credit card breach, or are they a serious state-backed group targeting a critical asset? The problem is that the measurable online behavior for these two very different attacks often looks identical, especially as hostile players are using increasingly sophisticated means of camouflaging their intent and origin. Compared to the military tactics of traditional warfare, cyber security is additionally complicated by the broader range of objectives each adversary may have. These include economic interests, social hacking as a form of political expression, organized crime, and state actors with offensive cyber operations. In the cyber domain, regulation is the primary weapon, and ISPs are the primary target. A crude analogy may be made between ISPs and commercial owners of major transport systems. As with any transport process, each packet, vehicle, or individual must be filtered and verified or malicious actors who use the network for hostile purposes will remain. Solving the problems of intent and regulation in the cyber domain will require a great deal of research and a broader psychological and sociological perspective. Another aspect of the problem in handling cyber attacks is that some are weak feints that precede a later full-scale assault, while others are background noise in the sea of malware. People tend to focus on the possible technical capabilities of hackers, but this is increasingly irrelevant as sophisticated attack tools are now free and ubiquitous.

For example, in China there is a complex mix of actors, such as criminal groups, state-backed industrial espio-

nage activity, and hacker/nationalistic students. While each of these groups has distinct objectives, they are similar in that they employ constantly evolving attack methods. Hence, the Chinese state makes use of its hacker sub-culture as part of nationalistic online campaigns and can therefore distance itself diplomatically from the hacker's behavior. Yet, the Chinese state also constantly monitors such hacker groups, as they use the Internet to express social dissent.

Three additional issues of specific technical complexity in the cyber domain that vex the policy debate include attribution, self-replication, and political control. First, cyber actors frequently use camouflage and mimicry as in natural ecosystems, thus making attribution difficult. This makes the selection of a response by policy makers inherently difficult, even though a range of proportionate responses exists.¹¹ As in the Stuxnet example, where digital forensics revealed a possible state origin of the attack (Israel), it

modify and adapt the code. Thirdly, the loss of government control, will, or capacity to enforce national cyber controls that limit the activity of organized cyber-criminal or political groups, like in former Soviet states, is the most challenging social-political aspect of cyber security.

Social Dimension. The cyber sphere plays an important role for society, but social issues also complicate cyber security. Cyberspace is driven by the actions of the individual members of human society; it is a powerful medium for social change precisely because it empowers individuals, which is why it is used so much. The quid pro quo is that this has disadvantaged the state in its ability to impose social control and centralize policies. Iran, for example, is engaged in erecting a cyber wall around the entire Iranian cyber domain, and China maintains a 'Great Firewall' around the networks in mainland China through state mandated control and censorship.¹³

Cyberspace is driven by the actions of the individual members of human society; it is a powerful medium for social change precisely because it empowers individuals.

was apparent that this could easily have been faked by a third party to implicate that state.¹² A second technical issue that muddles the policy debate is the ability of code to self-replicate. Malware can spread spontaneously, which is similar to trying to contain a bio-viral outbreak. Worse still is the fact that the code rapidly mutates as new actors

A strict censoring policy, like China's, might in fact increase cyber security, as Jason Healey aptly notes that, "a Balkanized Internet may actually improve many of the current security problems of cyberspace, as nations would have more levers to stop all kinds of unpleasant traffic."¹⁴ But the Internet teaches us that a free and open process

[84] Georgetown Journal of International Affairs

of human engagement and communication has the greatest social value.¹⁵ Hence in the Western hemisphere, we should tread very lightly before calling for draconian controls on individuals' activity in cyberspace, despite the potential benefit to cyber security.¹⁶

A cyber 'Wild West,' however, is not constructive either. Individuals need the protection of state laws and a national policy of education on safe cyber practice, especially given the exponential growth of social networking and the ensuing decrease in cyber security.

For example, the United Kingdom, which is embracing the online domain as a means of reducing the cost of delivering public services and advancing innovation and economic development, is also using a process of social dialogue to engage its entire population in constructively developing online standards for behavior.¹⁷ Yet in the summer of 2011, the United Kingdom witnessed some of the worst riots and social unrest in a generation, some of which were fueled and coordinated via cyber networks and social media, particularly through BlackBerry messenger.¹⁸ The ensuing debate over regulation versus personal freedom was predictable, but missed the point. Any tool inherently has positive and negative uses—what works is a process of accountability and social norms that regulate behavior.

Legal Dimension. From a legal perspective, the issues in the cyber domain revolve around protecting and balancing the rights of the individual versus those of wider society and organizations. But the exponential rate of evolution in the cyber domain outpaces

the speed of legal and judicial processes. The ongoing futile battles over digital rights management are evidence of this in action. Technology makes instant sharing of digital media a reality, which content creators need to substantively address, rather than resorting to punitive measures under the law.

However, the use of stricter legal measures against serious cyber crime can be a constructive tool in the normalization of the cyber domain as a safe environment for individuals to operate within. Current legal systems have failed to keep pace with the migration of crime into the cyber domain, and few states have empowered or resourced their police agencies to act effectively in cyberspace. Digital forensics in particular is often underfunded or poorly resourced, making convictions of serious online crime difficult. Careful consideration of the wider social consequences of cyber law is required, such that we avoid suppressing information and media sharing, but rather focus legal action on cases of serious harm or abuse. In more technical terminology, we require a 'non-linear' legal response. This echoes back to the Game Theory concepts discussed earlier where we need laws guided by a clear technical understanding of human responses to rewards and punitive measures, within a cyber context. Hence defending digital rights is best approached as a process of cultural norm development.

Cyber Demographics. A final issue of concern is the fundamental increase in the total cyber population, as another two billion people come online within the next two years, mostly from developing nations with minimal

cyber laws or treaty provisions to deal with cyber attacks that originate from within their borders. This alone will make the problem of attack attribution insurmountable. Attitudes towards digital copyright, censorship, cyber crime, privacy, and freedom of speech, which are already complex, will become vastly more so by the sheer cultural heterogeneity of the new wave of cyber citizens, with multiple religious, political, tribal, and racial facets. Even within relatively culturally homogenous regions, such as Western Europe, the differences in social attitudes towards cyber privacy and state censorship are immense: Germany has strict privacy laws driven by a deep historical fear of state intrusion, but in the United Kingdom, significant social trust in the state security apparatus remains relatively strong, resulting in weaker privacy laws.

Furthermore, most of the new users are poor, and many of the machines they use are running either counterfeit or open source operating systems and applications. Hence, they are at maximum risk of malware attack or for their machines to be used as botnet platforms. Many access the internet solely via smartphones, specifically Android devices, which have relatively weak security and are expected to become a major attack channel in the coming months, challenging cyber security efforts.¹⁹ In particular, the cyber emergence of Africa, India, and the South East Asian states, such as Vietnam, is occurring faster than local legal frameworks can adapt. Such states should be offered more expert assistance on best cyber practice across both their public and private cyber domains, ideally, via new international cyber security centers of

excellence.

Conclusion. Cyber security remains a difficult and unresolved problem, precisely because it is a complex adaptive system. This is a difficult message to convey, as we all seek simple technical or policy levers to resolve the issue of securing a computer network. The cyber research community has partly grasped that the cyber world is a complex adaptive system. A 2007 report by Goodman and Lin identifies that, "in many ways security is an emergent property of a complex IT system that depends on both the underlying system architecture and its implementation."²⁰ More recently, Stephanie Forrest has initiated research on bio-inspired defense strategies, which has the ongoing aim of understanding the complex adaptive nature of cyber threats and discussing means to counter them using similar adaptive strategies.²¹ The latest research in this domain was reported in the 2012 Adaptive Resilient Complex Systems (ARCS) workshop, and it focused on the social and economic dimensions, particularly through the use of social media channels as attack vectors.²²

The wider cyber security community, however, has yet to recognize the real nature of the threat and persists in utilizing rigid strategies based on boundary control, access management, or linear risk models. This new stance requires a deep philosophical shift, and there is no easy solution. There are better practices and defenses that can and must be implemented and maintained. Fundamentally, though, the best defense is to first understand the true nature of the problem. We

can then begin to adopt useful defense strategies, instead of offense strategies. And even though perfect cyber security is not an achievable state, we can achieve a dynamically stable and robust defense, ideally using a combination of signature and adaptive behavior-based responses. It may also be productive to consider Maynard Smith's idea of Evolutionary Stable Strategies (ESS) as a model of how the long-term dynamic behavior of offensive and defensive strategies will evolve in cyber security, and if the introduction of a new secu-

structures that have survived for centuries in a major earthquake zone. They should have been destroyed many years ago, but they remain standing because they are fluid, loosely coupled structures with a resilient design that absorbs quake shocks like a sponge. In contrast, any modern rigid steel and concrete building design in that area gets shaken to pieces. We need research into similar parallel design concepts within the cyber defense realm. The complicating issue is that this can incur greatly increased costs in the system specifications, such

The question is how to continue exploiting the creative social and economic value of the Internet while fulfilling the basic duty of the state to stafeguard.

rity mechanism will lead to a dynamically stable defensive effect over time. This is a difficult question to resolve for any complex adaptive system, and particularly for cyber security, which is so dependent on human socio-economic processes.

The best technical approach is to engineer all computing systems for resilience as an inherent quality. We need to reorient our design philosophy for all ICT systems, and especially cyber defense systems, to reflect this philosophy of resilient flexibility. An excellent example is the work by Arun Sood on adaptive Firewall design, using a mechanism known as Self-Cleansing Intrusion Tolerance (SCIT).²³ As a philosophical example, the beautiful Pagodas in Japanese ceremonial gardens are a curious anomaly: they are tall wooden

as through duplicated hardware or fail-safe software design. As such, there is an open research challenge to create resilient computing systems with a minimal cost increase.²⁴

Furthermore, we urgently need an improved science of cyber security driven by the establishment of interdisciplinary centers that connect academia, industry, national laboratories, and government agencies, in order to formalize our understanding of the complex and evolvable nature of the domain, as advocated in the JASON report²⁵ (This also happens to be a priority for the UK GCHQ and its new centers of excellence in cyber security).²⁶ Deeper international collaboration and the pooling of resources is also required with joint public and private sector information exchange

programs, ideally in the form of senior level standing councils with international representation.

At the social level, as discussed, there is a fine balance within democratic states between allowing freedom of online expression and preventing the use of cyberspace as a vector for malicious hactivism. For society as a whole, we clearly require a constant education program to raise awareness of cyber security and online social responsibility. Again this will cost a state resources and time, but it is vital to raise the collective cyber defense of a nation. At the legal level, the implications of the required paradigm shift are extensive and problematic.

In policy terms, the question is how to continue exploiting the creative social and economic value of the Internet while fulfilling the basic duty of the state to safeguard its cyber (and physical) domain. As in the discussed case of the riots of 2011 in the United Kingdom, the urge to impose new legal constraints on social media channels was severe, but a process of social dialogue around the causes of the unrest proved to be more productive.

Looking forward, it is crucial to address several distinct time-scale requirements for the short, medium, and long term. In the short-term, governments need to devote resources to educating the population, beginning in the primary-level and also training

future legal and policy makers, on best practices in cyber defense and awareness. In the medium-term, we need policy backing for new cyber centers, like the Santa Fe Institute in the United States, that put strong emphasis on an interdisciplinary focus and deep government and business engagement.²⁷ For the longer-term, we need a new science-based international cooperative effort to improve cyber defense for all states. The existing international system of CERT groups that operate globally to detect and remediate cyber-attacks, are primarily a reactive mechanism. Rather, we need more predictive and adaptive collaborative cyber institutions.

The comparison has been made between current cyber crime and piracy up to the sixteenth and seventeenth centuries, when strong international treaties and laws of the sea began to control the piracy problem. This analogy has merit and may act as a guiding principle for policy formulation; however, it is best not stretched too far. The pirates are no longer sailing off the coast of Jamaica, but rather live in your neighbor's garage, basement, office, college, and in entirely virtual worlds with no physical location.

The views expressed are entirely personal to the author and do not reflect those of British Telecommunication.

NOTES

- 1 Bruce Schneier, "Details of the RSA Attack," *Bruce Schneier Blog*, Internet, http://www.schneier.com/blog/archives/2011/08/details_of_the.html (date accessed: 2 September 2012).
- 2 John von Neumann, *Theory of Self-Reproducing Automata* (Urbana and London: Univ. of Illinois Press, 1966), Internet, <http://cba.mit.edu/events/O3.11.ASE/docs/VonNeumann.pdf> (date accessed: 2 September 2012).
- 3 Jason Healey, "The Five Futures of Cyber Conflict and Cooperation," *Georgetown Journal of International Affairs Special Issue: Cybersecurity* (2011) 110-117.
- 4 John H. Holland, "Studying Complex Adaptive Systems," *Journal of Systems Science and Complexity* 19, no.1 (2006): 1-8, Internet, <http://hdl.handle.net/2027.42/41486> (date accessed: 2 September 2012).
- 5 John von Neumann and Oskar Morgenstern, *Theory of Games and Economic Behavior* (Princeton University Press, 1944).
- 6 Further complicating matters, legitimate users may also choose to switch roles to become a defecting agent at any instant.
- 7 D. McMorrow, "Science of Cybersecurity," Internet, <http://www.fas.org/irp/agency/dod/jason/cyber.pdf> (date accessed: 2 September 2012), 2.
- 8 Nassim N. Taleb, *The Black Swan* (Penguin Books, 2008).
- 9 R. Pastor-Satorras and A. Vespignani, *Epidemic spreading in scale-free networks* (Physical Review Letters, 2001) 86, 3200-3203.
- 10 Schneier, *supra* note 1.
- 11 Herbert Lin, "Responding to Sub-Threshold Cyber Intrusion, A Fertile Topic for Research and Discussion," *Georgetown Journal of International Affairs Special Issue: Cybersecurity* (2011) 127-135.
- 12 Irving Lachow, "The Stuxnet Enigma – Implications for the Future of Cyber Security," *Georgetown Journal of International Affairs Special Issue: Cybersecurity* (2011) 118-126.
- 13 This massively limits what net users within China are allowed to see online and the Chinese state monitors internal traffic for signs of dissent activity. It also has a biasing economic effect in favor of Chinese companies by limiting competition from major international companies, such as Google, and therefore creating commercial opportunities for Chinese companies. In addition, a constant cyber battle exists between the Chinese state censors and micro-blogs of Chinese activist groups. This is yet another example of a complex adaptive social/political game being acted out in cyberspace.
- 14 Healey, *supra* note 3.
- 15 The antithesis of this process was the mindset of the Soviet and Communist block, in which an Orwellian state imposed its central view of what individuals required and should have access to. The consequences of that mindset are still with us and will require decades of economic and social development to remediate.
- 16 One of the reasons for the exponential growth in social networks is the fundamental human desire to communicate and interact. As more of an individual's social contacts go online, then the value of that individual following suit increases in rough proportion to Metcalfe's law. As such, the growth of social media is a nonlinear function, and the resulting virtual social network displays complex properties that are only loosely correlated with the physical world. Metcalfe's law states that the value of a telecommunications network is proportional to the square of the number of connected users of the system. Bob Briscoe, "Metcalfe's Law is wrong," *IEEE*, (July 2006), Internet, <http://spectrum.ieee.org/computing/networks/metcalfe-law-is-wrong> (date accessed: 2 September 2012).
- 17 "UK Cyber Challenge," Internet, <https://cybersecuritychallenge.org.uk/>.
- 18 Josh Halliday, "London Riots: Blackberry to help Police Probe Messenger looting role," *The Guardian*, 8 August 2011, Internet, <http://www.guardian.co.uk/uk/2011/aug/08/london-riots-blackberry-messenger-looting> (date accessed: 2 September 2012).
- 19 Dave Neal, "Android Phones Are A Big Security risk, Says Security Analyst Firm," *The Inquirer*, 27 February 2012, Internet, <http://www.theinquirer.net/inquirer/news/2155213/android-phones-security-risk-security-analyst-firm> (date accessed: 2 September 2012).
- 20 Seymour E. Goodman and Herbert S. Lin, "Toward a Safer and More Secure Cyberspace," *National Research Council*, (2007) 81, Internet, <http://www.nap.edu/catalog/11925.html> (date accessed: 2 September 2012).
- 21 In 2002, Forrest and a group of industrial researchers started a workshop series based at the Santa Fe Institute. Stephanie Forrest et al., "A Sense of Self for Unix Processes" (Los Alamitos: IEEE Computer Society Press, 1996) 120-128, Internet, http://webpages.math.luc.edu/~pld/courses/intrusion/sum08/class9/forrest.etal.1996.sense_of_self_for_unix_processes.pdf (date accessed: 2 September 2012).
- 22 "Adaptive Resilient Complex Systems Workshop series (ARCS)," *ARCS Workshop Blog*, (6 January 2012), Internet, <http://www.arcs-workshop.org> (date accessed: 2 September 2012).
- 23 Arun Sood, "Intrusion Tolerance to Mitigate Attacks that Persist," (Paper presented at Second Workshop on Cyber Security and Global Affairs, ETH, Zurich, 6 July 2010).
- 24 ARCS, *supra* note 21.
- 25 McMorrow, *supra* note 7.
- 26 GCHQ, "UK GCHQ establishes new centers of excellence in cyber security, 2012," Internet, <http://www.gchq.gov.uk/Press/Pages/Cyber-Security-Research-Centres-of-Excellence.aspx> (date accessed: 2 September 2012).
- 27 *Ibid*.